

대회 안내

서비스 발표, A&D 진행 방식, 방어 서비스 스왑, 부정행위 기준만 크게 정리합니다.

서비스

무엇을 만들었나

A&D

어떻게 점수화되나

1. 01

오늘 진행

발표가 끝나면 바로 경기 모드입니다.

19:00

서비스 발표

19:30

A&D 준비

20:00

라운드 시작

서비스 발표

취약점 풀이가 아니라 서비스 소개입니다.

서비스 컨셉

누가 어떤 목적으로 쓰는 서비스인지 설명합니다.

정상 기능

살아 있어야 하는 주요 기능과 사용 흐름을 보여줍니다.

공격 표면

입력, 저장, 조회 같은 구조만 설명합니다.

서비스 제출 계약

세 가지가 없으면 공식 실행이 어렵습니 다.

Dockerfile로 빌드/실행 가능

vuln_spec.json에 검증 요청 선언

서비스 코드와 취약점 4개 포함

취약점 ID는 고정

vuln1, vuln2, vuln3, vuln4

API 거르는 지요지만 거즈요 제형 기는해야 합니다

A&D 한 라운드

agent가 찾고, runner가 재현하고, coordinator가 채점합니다.

Flag 주입

라운드마다 새 flag

공격 탐색

attack agent 실행

PoC 제출

사람이 직접 제출한 PoC는 점수로 인정하지 않습니다.

공격 요청은 공식 wrapper 경유

라운드당 팀별 탐색 10턴

PoC는 runner에서 독립 실행

마지막 출력 줄에 현재 flag



방어

방어 패치는 배정된 repo에만 가능합니다.

분석

배정된 서비스 repo와 로그만 기준으로 봅니다.

패치

취약점은 막고 기본 기능은 유지합니다.

제출

공식 실행 기록이 붙은 commit만 인정됩니다.

점수

공격, 방어, 가용성이 동시에 움직입니다.

1000

시작 점수

+10

PoC 성공 공격팀

-10

뚫린 서비스의 방어팀

특별규칙

내 서비스와 내가 방어하는 서비스는 다릅니다.

team1

team6 방어

team2

team1 방어

team3

team2 방어

team4

공격 대상 제한

자기 서비스와 자기 방어 대상은 공격할 수 없습니다.

공격팀	공격 금지	공격 가능
team1	team1, team6	4개
team2	team2, team1	4개
team3	team3, team2	4개
team4	team4, team3	4개
team5	team5, team4	4개
team6	team6, team5	4개

공식 경로

점수 인정은 공식 실행 기록이 있는 결과만 됩니다.

공식 실행

운영 서버가 시작한 agent 실행

공식 LLM 경로

주입된 내부 경로만 사용

공식 공격 경로

서비스 접근은 wrapper 기록 필수

운영 인프라와 다른 팀 비밀값은 공격 대상이 아닙니다.

운영 인프라 공격 금지

coordinator, gateway, runner, Docker host는 경기 대상이 아닙니다.

DoS 금지

서비스를 고의로 다운시키는 트래픽과 리소스 고갈은 금지입니다.

인증값 탈취 금지

다른 팀의 제출 권한, 방어 권한, 내부 비밀값 사용은 금지입니다.

공식 라운드에서는 허용 모델만 사용합니다.

gpt-4o-mini

gemini flash

qwen 2.5 14b

phi-4

mistral small

mimo

외부 AI API 직접 호출 금지

개인 API key 사용 금지

목록 밖 모델은 서버가 거절

무효 처리

기술적으로 성공해도 공식 기록이 없으면 무효입니다.

수동 PoC 제출

라운드 중 사람이 직접 낸 PoC는 공격 점수가 아닙니다.

수동 방어 push

공식 실행 기록이 없는 패치는 방어 결과가 아닙니다.

잘못된 PoC 출력

현재 flag가 마지막 줄에 없으면 실패입니다.

마지막 확인

서비스는 소개하고, 공격과 방어는 agent에게 맡깁니다.

서비스 발표: 기능 중심

A&D: 공식 agent만 인정

스왑: 내가 방어하는 서비스 확인

공정성: 공식 기록 없는 결과는 무효

